

Plantilla de Reporte Ejecutivo – GQM + PRAGMATIC + OWASP 2025

Estructura recomendada de presentación (PowerPoint/Keynote) para explicar a la alta dirección cómo se han diseñado las métricas OWASP, cómo se han evaluado con PRAGMATIC y qué implicaciones tienen para NIS2/ENS.

Diapositiva 1 – Portada

- Título sugerido:
"Métricas OWASP 2025: de la vulnerabilidad al objetivo nacional".
- Subtítulo:
"Marco GQM + PRAGMATIC aplicado a [Nombre de la organización / Sector / España]".
- Información adicional:
- Nombre y cargo del ponente (CISO, Responsable de Riesgos, etc.).
- Fecha.

Diapositiva 2 – Mensaje clave

- 3–5 bullets con ideas centrales, por ejemplo:
- Hemos pasado de contar vulnerabilidades a medir objetivos de ciberresiliencia alineados con NIS2 y ENS.
- Usamos OWASP (Top 10:2025, SAMM, ASVS) como base técnica común.[web:2][web:68][web:97][web:100]
- Cada indicador (M1–M15) se ha definido con GQM y se ha evaluado con PRAGMATIC.
- Seleccionamos un conjunto de métricas "estrella" para cuadros de mando y supervisión.
- El Índice Global de Madurez (IGM) permite situar a la organización frente a su sector.

Diapositiva 3 – Por qué cambiar de métricas

- Problemas típicos de las métricas tradicionales:
- Enfoque en volumen (número de incidencias, vulnerabilidades) sin conexión clara con objetivos.
- Dificultad para explicar su significado a negocio o a la alta dirección.
- Falta de trazabilidad con requisitos de NIS2 y ENS.[web:21][web:24][web:60][web:72]
- Oportunidad:
- Usar OWASP como lenguaje técnico estándar.
- Usar GQM y PRAGMATIC para asegurar que las métricas sirven para algo más que decorar informes.

Diapositiva 4 – GQM en 30 segundos

- Esquema visual (texto en la diapositiva):
- Goal: meta de negocio / nacional (ej.: reducir exposición a A01–A03 en servicios esenciales).
- Question: preguntas que nos dicen si avanzamos (ej.: ¿qué % de activos críticos está libre de esas vulnerabilidades?).
- Metric: dato medible que responde (ej.: M2 – % de activos críticos sin vulns A01–A03).
- Nota: señalar que GQM garantiza que ningún indicador está “flotando” sin meta asociada.[web:87][web:95][web:98]

Diapositiva 5 – PRAGMATIC en 30 segundos

- Explicar que PRAGMATIC evalúa cada métrica según nueve criterios:
- Predictivo, Relevante, Accionable, Genuino, Significativo, Preciso, Oportuno, Independiente, Rentable.[web:88][web:91][web:94][web:96]
- Resaltar en una frase:
- "No toda métrica buena técnicamente es buena para la gestión; PRAGMATIC nos ayuda a separar el grano de la paja".

Diapositiva 6 – Catálogo de indicadores M1–M15

- Tabla simplificada con 2–3 columnas:
- ID (M1–M15).
- Tema (Top 10, SAMM, ASVS, Riesgo, Gobernanza).
- Descripción breve.
- Nota visual: destacar con un color los indicadores que puntúan mejor en PRAGMATIC.

Diapositiva 7 – Ejemplo detallado (M2)

- Mostrar el flujo GQM completo para M2:
- Meta: robustez de activos críticos frente a A01–A03.
- Preguntas clave (3–4 bullet points).
- Métrica M2: definición, unidad, fuentes.
- Mostrar una pequeña tabla con las puntuaciones PRAGMATIC de M2.

Diapositiva 8 – Matriz PRAGMATIC (visión agregada)

- Heatmap o tabla resumen:
- Métricas en filas.
- Criterios PRAGMATIC en columnas.
- Colores según nota (0–5).
- Mensaje: identificar rápidamente métricas "estrella" y métricas de segundo nivel.

Diapositiva 9 – Índice Global de Madurez (IGM)

- Explicar estructura del IGM:
- Subíndices: Exposición OWASP, SAMM, ASVS, Gobernanza/Cultura.
- Escala 0–100.
- Gráfico propuesto:
- Radar con los cuatro subíndices.
- Mensaje: permite ver de un vistazo dónde estamos más débiles.

Diapositiva 10 – IGM y sector / benchmark

- Mostrar la posición de la organización frente a:
- Media sectorial.
- Rango de pares.
- Gráfico sugerido:
- Barras comparativas o boxplot de IGM.
- Mensaje: situar la conversación en clave de competitividad y cumplimiento.

Diapositiva 11 – Alineamiento con NIS2 y ENS

- Tabla o diagrama que muestre:
- Cómo M1–M15 alimentan ámbitos NIS2 (gestión de riesgos, medidas técnicas, gobernanza, cadena de suministro, continuidad).
- Qué dominios ENS se ven cubiertos (riesgos, medidas, continuidad, coordinación con CSIRTs).
[web:21][web:24][web:60][web:72][web:77]
- Objetivo: dejar claro que esto no es un ejercicio académico, sino un soporte a obligaciones reales.

Diapositiva 12 – Selección de métricas para el cuadro de mando

- Seleccionar 6–8 métricas "core" según su puntuación PRAGMATIC y relevancia regulatoria (por ejemplo, M2, M4, M9, M12, M14, M15).
- Mostrar en una tabla:
- Métrica.
- Nota PRAGMATIC global.
- Función en el cuadro de mando (KPI/KRI, alerta temprana, diagnóstico en profundidad).

Diapositiva 13 – Impacto en decisiones y ROI

- Conectar brevemente:
- Mejora en IGM y subíndices → reducción estimada de riesgo (menos incidentes, menor impacto).
[web:99]
- Costes de seguridad – inversión.
- Fórmula conceptual de ROI de seguridad.
- Mensaje: las métricas permiten defender inversiones no como “coste hundido”, sino como mitigación cuantificable de riesgo.

Diapositiva 14 – Hoja de ruta

- Propuesta en 3 fases:
- Fase 1: Implementar medición de M1–M15 y cálculo de IGM (6–12 meses).
- Fase 2: Ajustar métricas, umbrales y PRAGMATIC según experiencia (12–24 meses).
- Fase 3: Integrar métricas en planes estratégicos, contratos y supervisión regulatoria.

Diapositiva 15 – Cierre y llamada a la acción

- Mensaje final:
- "Si queremos que NIS2/ENS no sean solo un ejercicio de compliance, necesitamos métricas que midan lo que importa y permitan actuar".
- Próximos pasos concretos:
- Validar el catálogo de métricas.
- Aprobar la implantación del modelo GQM + PRAGMATIC.
- Fijar un calendario de mediciones y revisiones.

Esta plantilla está pensada para que un CISO pueda explicar, en menos de una hora y con cierto estilo, por qué el nuevo sistema de métricas merece existencia propia en la agenda de dirección y no solo en el disco duro del equipo de seguridad.